

《信息系统安全》第十三讲

数据库安全

Part I 数据库安全的一般性原理

2023年12月11日

周亚建

yajian@bupt.edu.cn

Overview of Last Class

你是否遇见过操作系统安全问题？

你遇见的安全情况是什么症状？

你是怎么解决的？

近一年全球十大数据安全事件

Facebook: 5.33亿用户信息泄露

据安全研究人员Alon Gal称，来自106个国家的超过5.33亿Facebook用户的个人信息已被免费在线泄漏，包括不少知名人士和公众人物，还包括超67万的国内用户，泄露的信息包括用户在脸书的账户名、位置、生日以及电子邮件地址等信息，非常详细。

事件起因在于一个2020年的漏洞，该漏洞使用户能够使用Telegram机器人来利用Facebook系统。此漏洞导致在低级黑客论坛上，以几欧元的价格就能轻松买到这些数据。



http://news.sohu.com/a/537792640_121351677

近一年全球十大数据安全事件

T-Mobile: 四年内第六次数据泄露

2021年8月，美国电信巨头T-Mobile官方确认服务器被黑客入侵，正在调查数据泄露。最终已经证实，最近入侵其服务器的攻击者窃取了包含数千万个人信息的文件。本次入侵大规模影响了大约780万T-Mobile后付费用户、850000名T-Mobile预付费用户以及大约4000万以前或潜在用户。根据T-Mobile官方统计，加起来，攻击者窃取4860万人的记录，包括当前、以前或潜在的T-Mobile客户。





数据库安全——绪论

数据库系统的目标

ORACLE®
DATABASE

IBM Db2
Database


Microsoft®
SQL Server®


MySQL®

提供数据共享，统一管理数据

减少数据冗余

简化应用程序对数据的访问

解决数据一致性问题

保证数据独立性

GaussDB

GBASE®



达梦数据库

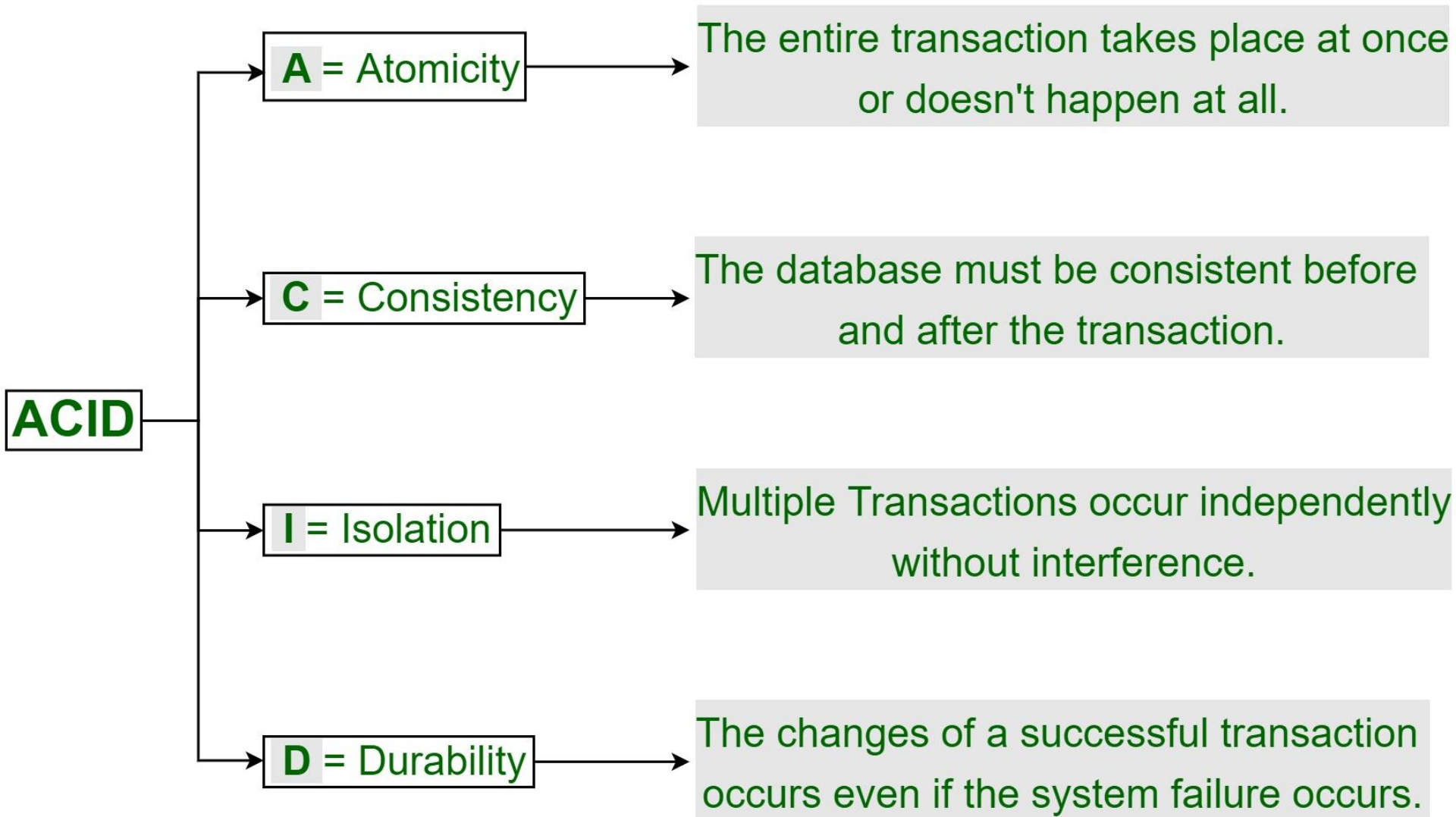
SequoiaDB
巨杉数据库

OceanBase
A Powerful Database System

PingCAP

问题：信息集中存放，一旦受损，后果严重；且极易成为攻击目标

ACID Properties in DBMS



数据库的漏洞

缺省安
装漏洞

数据库设
计缺陷

数据库漏洞的种类繁多和危害性严重是数据库系统受到攻击的主要原因

数据库产
品的bug

人为使用
上的漏洞

通过研究数据库漏洞分类，有助于人们深入理解漏洞并加以预防和避免

设计缺陷：明文存储引起的数据泄密

- ❖ 在当前的主流数据库中，数据以明文形式放置在存储设备中，存储设备的丢失将引起数据泄密风险
- ❖ 数据库数据文件在操作系统中以明文形式存在，非法使用者可以通过网络接触到这些文件，从而导致数据泄密风险

通过UltraEdit这样的文本工具即可得到部分明文信息，通过DUL/MyDUL这样的工具能够完全实现将数据文件格式化导出



典型数据库泄密案例：7天酒店数据库被盗

会员人数超过1650万，酒店总数逼近600家，在美国纽约证券交易所上市的7天连锁酒店集团无疑是国内经济型连锁酒店集团的龙头企业之一，但7天酒店在国内黑客圈中已经成了“明星”。

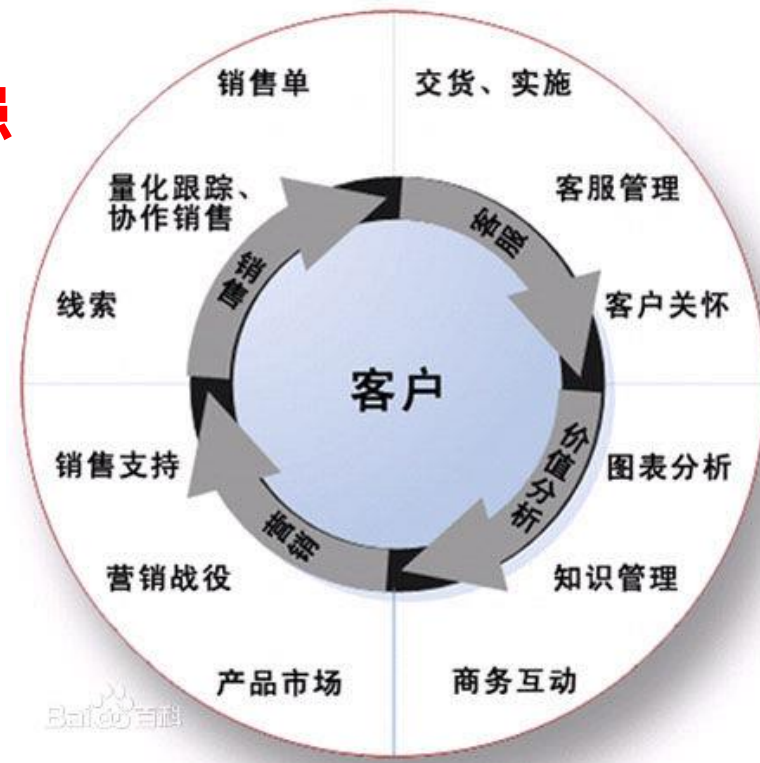
- ❖ 黑客通过“刷库”直接盗走整个数据库数据。即黑客利用企业网站存在的漏洞入侵数据库服务器，直接将整个数据库文件拷贝，通过DUL/MyDUL这种类似的工具将所有二进制方式存储的数据还原成清晰的格式化数据。

设计缺陷： **SYSDBA/DBA等超级用户的存在**

- ❖ 以sys和sa为代表的数据库系统管理员，可以访问到任何数据；
- ❖ 除了系统管理员，以用户数据分析人员、程序员、开发方维护人员为代表的特权用户，在特殊的时候也需要访问到敏感数据，从而获得了权限。

这些都为数据的泄密留下了极大的隐患

例如，掌握特权用户口令的维护人员，一旦进入了 CRM（Customer Relationship Management，即客户关系管理系统），只需具有对数据库的只读性访问权限就可以访问、读取数据库内的任何表，包括信用卡信息、个人信息。



设计缺陷：无法鉴别应用程序的访问是否合法

- ❖ 对于合法的数据库用户，通过合法的业务系统访问数据是正常的行为，但是数据库的一个缺陷在于，无法鉴别应用程序的合法性。
- ❖ 在现实系统维护或开发过程中，应用系统后台使用的合法数据库用户，常由于人为因素或管理不善，用户名及口令很容易泄露给第三方，第三方则可以通过命令行或管理工具直接访问数据库，批量窃取数据。

数据库产品bug: 缓冲区溢出

- ❖ 这类漏洞是由于不严谨的编码，使数据库内核中存在对于过长的字符串、函数参数、SQL语句、返回数据等不能进行严谨的处理，造成代码段被覆盖。
- ❖ 通过覆盖的代码段，黑客可以对数据库服务器进行各种操作，最常见的是使数据库崩溃，引起拒绝服务。

数据库产品bug: 缓冲区溢出

例如，SQL Server中利用缓冲区溢出，攻击者可以通过以下函数或存储过程执行任意代码：

RAISERROR、FORMATMESSAGE、xp_sprintf、sp_Mscopyscriptfile、xp_sqlinventory、xp_sqlagent_monitor、sp_OACreate、sp_OAMethod、sp_OAGetProperty、sp_OASetProperty、sp_OADestroy。

另外，xp_peekqueue、xp_displayparamstmt、xp_execresultset等40多个函数或扩展存储过程也存在缓冲区溢出。

数据库产品bug: 拒绝服务攻击漏洞

- ❖ 数据库中存在多种漏洞，可以导致拒绝服务访问，如命名管道拒绝服务、拒绝登录、RPC请求拒绝服务等。

例如Microsoft SQL 7.0服务允许远程攻击者通过不正确格式的TDS数据包引起拒绝服务；本地或远程用户通过向命名管道发送一个长请求引发拒绝服务。

例如MySQL中Data_format()函数在处理用户提交的参数时存在漏洞，畸形的参数数据会导致MySQL服务器崩溃。

TDS是一种协议、一系列描述两个计算机间如何传输**数据**的规则，它定义了传输信息的类型和他们传输的顺序。

数据库缺省安装漏洞：数据库安装后的缺省用户名和密码

- ❖ 在主流数据库中往往存在若干缺省数据库用户，并且缺省密码都是公开的，攻击者完全可以利用这些缺省用户登录数据库

例如，Oracle中有sys、system、sysman、scott等700多个缺省用户；

例如，MySQL本机的root用户可以没有口令。

数据库缺省安装漏洞：数据库安装后低安全级别设置

❖ 数据库安装后的缺省设置，安全级别一般都较低

例如，如MySQL中本地用户登录和某些远程主机登录不校验用户名密码；

例如，Oracle中不强制修改密码、密码的复杂度设置较低、不限定远程链接范围、通信为明文等。

数据库缺省安装漏洞：启用不必要的数据库功能

- ❖ 在数据库的缺省安装中为了便于使用和学习，提供了过量的功能和配置

例如，Oracle安装后无用的示例库、有威胁的存储过程；

例如，MySQL的自定义函数功能。

人为使用漏洞：过于宽泛的权限授予

在很多系统维护中，数据库管理员并未细致地按照最小授权原则给予数据库用户授权，而是根据最为方便的原则给予了较为宽泛的授权

例如，一个普通的数据库维护人员被授予了任意表的创建和删除、访问权限，甚至是给予DBA角色；

例如，一个大学管理员在工作中只需要能够更改学生的联系信息，不过他可能会利用过高的数据库更新权限来更改分数。

人为使用漏洞： 口令复杂度不高

- ❖ **弱口令**：通过暴力破解，攻击者不断地输入用户名和密码组合，直到找到可以登录的一组。通常，攻击者会使用自动化程序来加快暴力过程的速度。口令破解的工具有很多，并且通过Google搜索或sectools.org等站点就可以轻易地获得，这样就会连接到Cain、Abel或John the Ripper等流行的工具。
- ❖ **密码曝光**：一些公众权限的存储过程、表的调用会导致密码曝光
例如，通过执行公众权限的存储过程msdb.dbo.sp_get_sqlagent_properties可以获得SQL Agent密码；
通过查询公众权限的表RTblDBMProps可查看DTS密码；
Microsoft SQL Server允许本地用户通过数据转换服务（DTS）包属性对话框获得数据库密码。

人为使用漏洞： 口令复杂度不高

例如， Oracle 10.1 及早期版本， `sysman` 用户的密码明文存储在 `emoms.properties` 中。10.2之后，虽加密存储，但密钥也存在该文件中，且用DES算法，很容易解密。

因此建议管理员细致地按照最小授权原则给予数据库用户授权；数据库用户口令长度应大于等于10，并且应该包括字母和数字，应该通过一个口令检验函数来实施这一点。

人为使用漏洞：数据库未及时修复漏洞

- ❖ 数据库管理员担心修复最新漏洞会影响功能，但是却不担心修复周期无限期拖延会让最业余的攻击者都能够窃取大量数据。
- ❖ “一些大漏洞会在每个补丁中进行修复，而利用代码也总是可以在网上找到，攻击者可以剪切粘贴来用于攻击”Application Security公司的首席技术官Josh Shaul表示。

人为使用漏洞：没有自我检查

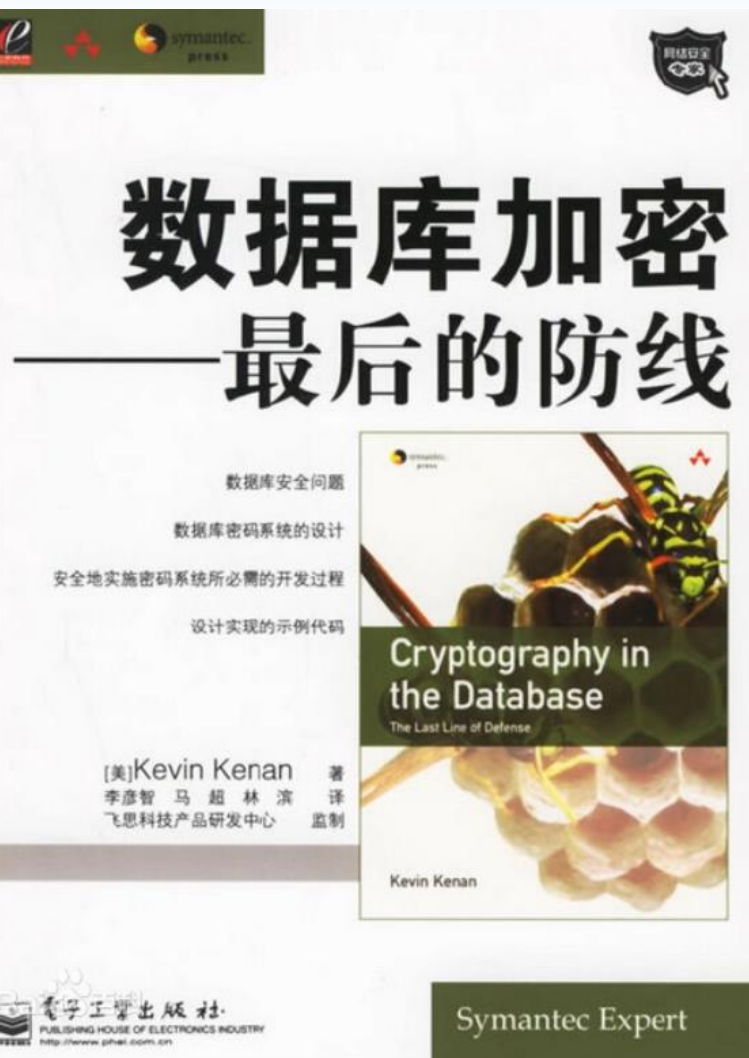
- ❖ 大多数企业没有监测用户或者审计数据库行为（用户在做什么，数据库是如何被使用的，数据库容易受到哪种类型的攻击等），因为他们并不担心会受到攻击

人为使用漏洞： 允许任意互联网连接和输入

- ❖ 当数据库连接到互联网时，任意客户端都可以不受限制地访问数据库，这样的话，不好的事情也将发生。
- ❖ “这意味着 SQL 注入攻击将造成毁灭性影响，将泄漏任意数据，”Arbor Networks公司安全研究高级经理Jose Nazario表示，“将权利和角色分开还有很长一段路要走，可以使用只读角色来用于WEB服务。”

用户输入需要被监测以防止注入和拒绝服务攻击，并且不受信任的用户应该永远不能直接查询表格或者数据库对象名称，例如表格、函数或者视图。

人为使用漏洞：没有加密数据



根据403 Web Security公司首席执行官Alan Wlasuk表示，最简单最愚蠢的数据库安全错误就是没有加密他们的数据库。

“这样就能让攻击者最终进入你的数据库，攻击者很难进入加密的数据库，加密是必须的、快速和易于使用的。”

数据库系统面临的安全威胁

按照导致的后果分类

- 信息泄露：未授权的用户有意/无意得到的信息。
- 数据修改：未授权的数据修改，违反信息完整性。
- 拒绝服务：影响用户访问和数据库资源的使用。

按照发生的方式分类

偶然的、无意的侵犯或破坏

- 自然或意外的灾害
- 硬件或软件的故障/错误导致的数据丢失和泄露
- 人为的失误

蓄意的侵犯或敌意的攻击

- 授权用户滥用、误用其权限
- 病毒、特洛伊木马、天窗（后门）、隐通道
- 绕过DBMS直接对数据进行读写
- 为了某种目的，故意把错误数据注入数据库，使之保存错误信息并随着时间的推移扩散

按照表现形式的分类

- | | |
|---|---|
| <ul style="list-style-type: none">• 滥用过高权限• 滥用合法权限• 权限提升• 平台漏洞 | <ul style="list-style-type: none">• SQL注入• 审计记录不足• 拒绝服务 |
|---|---|

数据库系统面临安全威胁的表现形式

滥用过高权限：用户（或应用程序）被授予超出了其工作职能所需的数据库访问权限时，这些权限可能会被恶意滥用。

滥用合法权限：将合法的数据库权限用于未经授权的目的

- 正常情况：医务人员可通过Web 应用程序查看单个患者病历的权限。通常情况下，该Web应用程序限制用户只能查看单个患者的病史，即无法同时查看多个患者的病历并且不允许复制电子副本。
- 恶意滥用权限：恶意的医务人员可通过使用其他客户端连接到数据库，来规避这些限制。通过其他客户端程序以及合法的登录凭据，该医务人员就可以检索和保存所有患者的病历。

Ex: 私自复制患者病历数据库的副本是违规行为

恶意的医务人员会将患者病历用于金钱交易。

员工由于疏忽将检索到的大量信息存储在自己的客户端计算机上，用于合法工作目的。一旦数据存在于终端计算机上，就可能成为木马以及记本电脑盗窃等的攻击目标。

权限提升：利用数据库平台软件的漏洞将普通用户的权限转换为管理员权限。漏洞可以在**存储过程、内置函数、协议实现**甚至是**SQL语句**中找到。

Ex: 金融机构的软件开发人员可以利用有漏洞的函数来获得数据库管理权限。使用管理权限，恶意的开发人员可以禁用审计机制、开设伪造的账户以及转账等。

数据库系统面临安全威胁的表现形式

平台漏洞：底层操作系统（WIN 2000、UNIX 等）中的漏洞和安装在数据库服务器上的其他服务中的漏洞可能导致未经授权的访问、数据破坏或拒绝服务。

Ex：“冲击波病毒”就是利用了Win 2000的漏洞为拒绝服务攻击创造条件。

SQL注入：入侵者通常将未经授权的数据库语句插入（或“注入”）到有漏洞的SQL数据信道中。通常情况下，攻击所针对的数据信道包括存储过程和Web应用程序输入参数。然后，这些注入的语句被传递到数据库中并在数据库中执行。使用SQL注入，攻击者可以不受限制地访问整个数据库。

审计记录不足：自动记录所有敏感的和/或异常的数据库事务应该是所有数据库部署基础的一部分。如果数据库审计策略不足，则组织将在很多级别上面临严重风险。

拒绝服务：在此攻击中正常用户对网络应用程序或数据的访问被拒绝。可以通过多种技巧为拒绝服务（DoS）攻击创造条件，其中很多都与上文提到的漏洞有关。

数据库系统安全需求

DBMS的安全保护

系统运行安全——运行环境的安全（管理）

- ❖ 法律、政策的保护；
- ❖ 物理控制安全，如机房加锁、防火、防盗等；
- ❖ 硬件运行安全；
- ❖ 操作系统、网络安全，如数据文件是否保护等；
- ❖ 灾害、故障恢复；
- ❖ 死锁的避免和解除；
- ❖ 防止电磁信息泄漏。

法律、政策的保护



2021年9月1日起正式实施

中华人民共和国 数据安全法

含草案说明

中国法制出版社

《数据安全法》（2021）与《国家安全法》（2015）、《网络安全法》（2017）、《网络安全审查办法》（2020）共同构成我国数据安全范畴下的法律框架。《数据安全法》作为我国第一部专门规定“数据”安全的法律，明确对“数据”的规制原则。

明确将数据安全上升到国家安全范畴

数据库系统安全需求

DBMS的安全保护

系统信息安全——技术

- ❖ 用户身份标识与鉴别
- ❖ 用户访问控制权限
- ❖ 数据存取权限、方式限制
- ❖ 审计跟踪
- ❖ 数据加密

数据库系统安全需求

数据安全

- ❖ **防止非法数据访问**：DBMS必须根据用户或应用的授权检查访问请求，保证仅授权用户访问数据库。

——和操作系统文件访问控制有什么不同？

- ❖ **防止推理**：防止用户通过推理得到机密信息（根据安全策略用户无权访问）

——这个问题在统计数据库中更加普遍。

- ❖ **保证数据库的完整性**——数据的正确性和相容性

- ① 数据库的物理完整性 ② 数据库的逻辑完整性
- ③ 数据库元素完整性

数据库的物理完整性

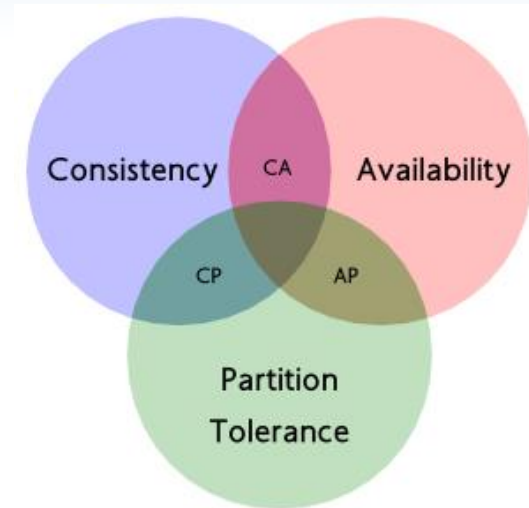
数据库的**数据文件**不受停电、失火等灾难的影响，可重建被灾难破坏的数据库。

DBMS提供的方法

- 定期**备份**数据库系统中的所有数据文件：脱机备份、联机备份、完整备份、增量备份、异地备份。
- 在故障点重建数据库：DBMS采用REDO和UNDO**日志**，在发生故障之后重启DBMS时使数据库恢复到故障前的状态。
- **双机热备份**：保持主从备份数据库的一致，当主数据库发生故障，**从数据库自动取代主数据库**。

数据库的逻辑完整性

保护数据库的结构不受到破坏



DBMS提供的方法

- 完整性约束
数据值的约束、唯一性约束、引用完整性约束
- DBMS能够对并发事务加以控制，保证数据的一致性、相容性和数据库的完整性

数据库的元素完整性

数据库元素的正确性或准确性

DBMS提供的方法

- DBMS可以利用域检查，确保某个域的所有值在合适的范围之内。
- 访问控制：规定有指定权限的用户访问他可以访问的数据。

数据库系统安全需求

访问控制

- ① 限制一些用户使其只能对数据库某些授权的数据子集进行访问或修改；
- ② 限制非法用户对数据库的任何访问行动，以免数据丢失或泄露。

困难的问题——访问控制难以解决的

- ① 当前多数DBMS访问控制粒度是表和列，不能到行；
- ② 推理：从已获得的数据和现有的知识推断更多的数据。

数据库系统安全需求

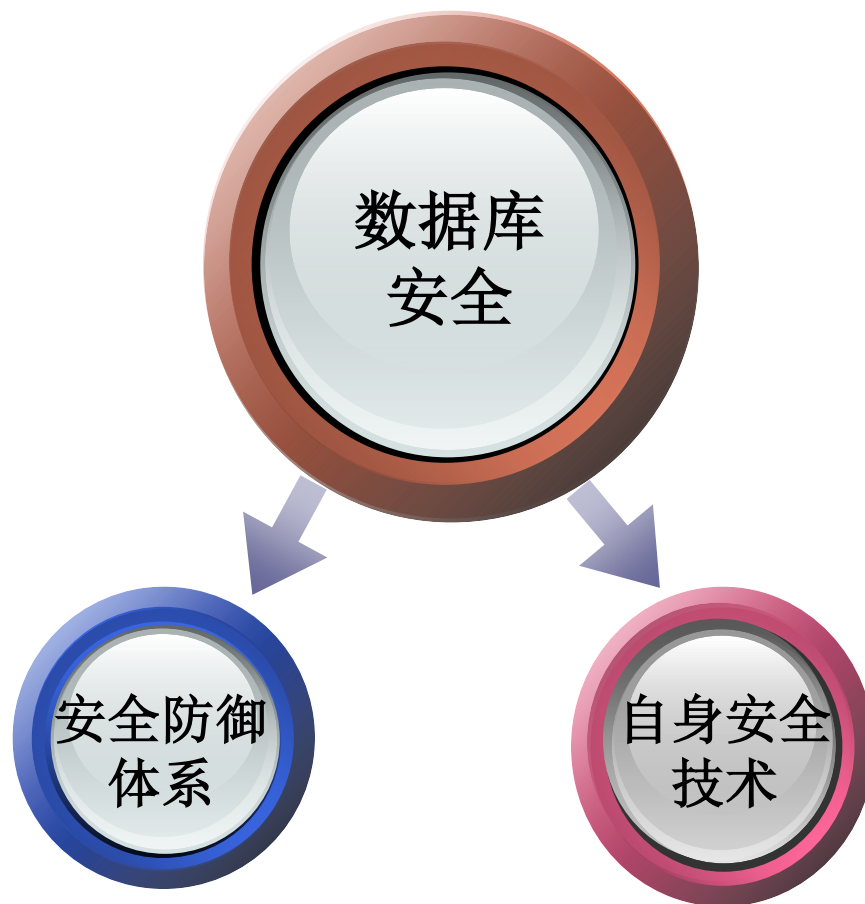
其他

- ❖ 审计和日志——事后取证
- ❖ 标识与鉴别——建立帐号、验证身份
- ❖ 机密数据的管理——数据加密
- ❖ 多级保护——基于BLP模型的多级安全保护
- ❖ 限界——防止程序之间出现非授权的信息传递



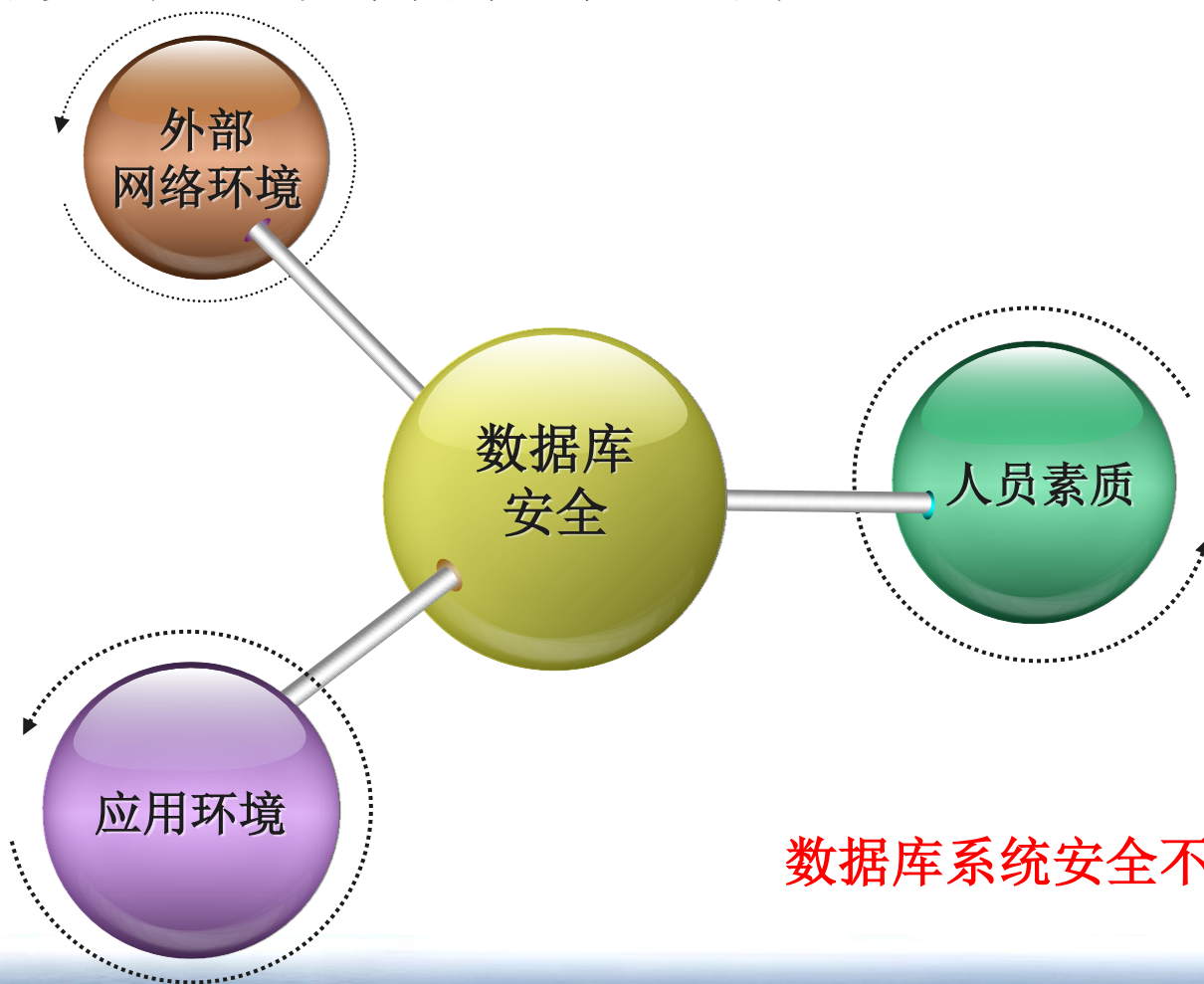
数据库安全技术

数据库安全技术



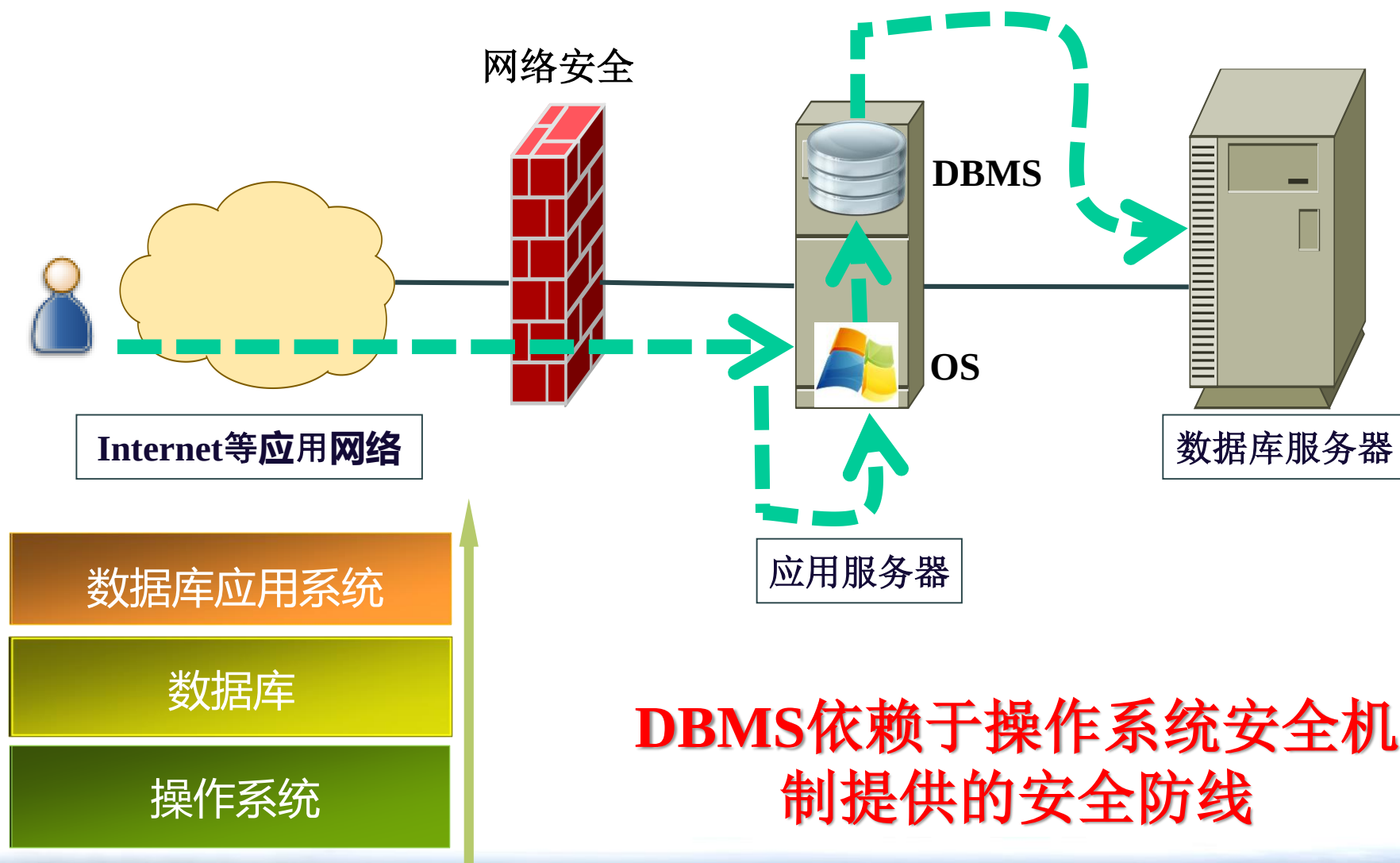
数据库系统的安全框架

数据库系统的安全除依赖自身内部的安全机制外，还与外部网络环境、应用环境、从业人员素质等因素息息相关。



数据库系统安全不是孤立的！

数据库系统的安全防御体系



数据库系统的安全防御体系

数据库安全体系按照层次划分可以分为：



这三个层次构筑成数据库系统的安全体系，与数据安全的关系是逐步紧密的，防范的重要性也逐层加强，从外到内、由表及里保证数据的安全。

数据库安全与操作系统之间的关系

	保护粒度	数据相关性
操作系统	文件级	数据少
数据库	细粒度，基于文件内容相关	有复杂关联的数据

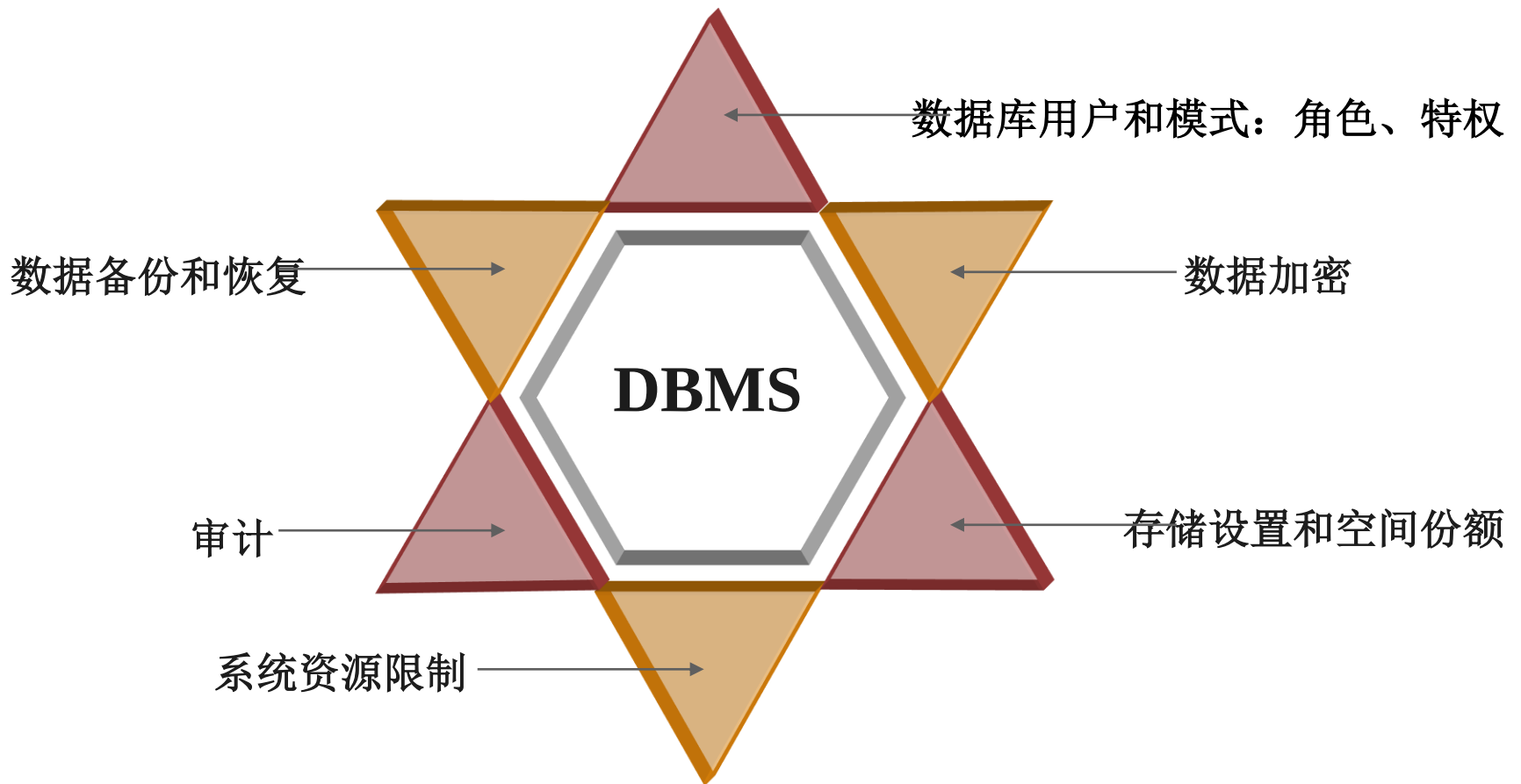
- ❖ 数据生命周期和访问频率
- ❖ 数据字典的管理
- ❖ 逻辑对象和物理对象
- ❖ 数据类型的丰富程度

数据库安全与操作系统之间的关系

DBMS应当充分利用操作系统已经提供的安全措施

- ❖ 标识、鉴别、审核用户
- ❖ 隔离用户进程，使之不致互相干扰
- ❖ 为DBMS提供第一道防线，使其它用户不得绕过DBMS直接存取库中的数据
- ❖ 建立在文件系统上的安全机制，例如访问控制、审计、隐通道检测等

DBMS提供的安全机制



数据库系统的安全防范措施

用户管理——标识与鉴别

- ① **标识**：对注册到数据库管理系统的用户进行唯一性标识，用户标识信息是公开信息，一般以用户名或者用户ID实现——**建立账号的过程**
- ② **鉴别**：对登录到数据库管理系统的用户身份的真实性进行验证的过程。通过对用户所提供的“鉴别信息”的验证，证明用户确实有所声称的某种身份。目前大多数DBMS采用口令

标识和鉴别的技术进展：IC卡信息、人体生物特征（指纹、视网膜）、CA认证

数据库用户及权限——角色的优点

▪减少特权管理

无需显式地将同一特权组授权给几个用户，只需将这特权组授权给角色，然后将角色授权给每一用户。

▪动态特权管理

如果一组特权需要改变，只需修改角色的特权，所有授给该角色的全部用户的安全域将自动地反映对角色所作的修改。

▪特权的选择可用性

授权给用户的角色可选择地使其使能（可用）或使不能（不可用）。

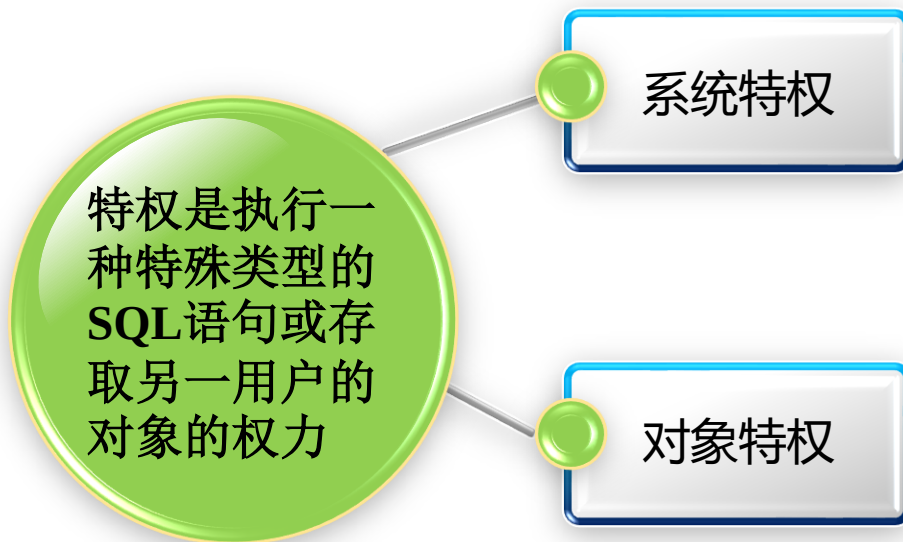
▪应用可知性

当一用户经一用户名执行应用时，该数据库应用可查询字典，将自动地选择使角色使能或不能。

▪专门的应用安全性

角色使用可由口令保护，应用可提供正确的口令使用权角色使能，达到专用的应用安全性。因用户不知其口令，不能使角色使能。

数据库用户及权限——特权



是执行一个特殊动作或者在对象类型上执行一种特殊动作的权利。
ORACLE有60多种不同系统特权，每一种系统允许用户执行一种特殊的数据库操作或一类数据库操作。

在指定的表、视图、序列、过程、函数或包上执行特殊动作的权利。

什么是数据库加密系统

能够对数据库中的明文数据进行加密，并以密文保存。



当合法用户读取数据时，系统能够将密文解密成明文返回给用户的系统。

数据库加密的必要性

数据库管理系统（DBMS）作为计算机系统的核心软件担负着存储和处理大量信息的任务，容易成为黑客攻击和内部管理人员攻击的重要目标。

数据库加密的必要性

- 数据库管理员的权力至高无上，既负责各项系统管理工作，又可以查询数据库中的一切信息；
- OS和DBMS对数据库文件缺乏有效的保护措施，有经验的网上黑客会直接利用OS工具窃取或篡改数据库文件内容。
——若数据库是经过加密的，得不到想要的数据；
- 原始数据以可读形式存放在数据库中

数据库加密技术的方式



数据库加密
有三种方式

数据库加密技术——库外加密

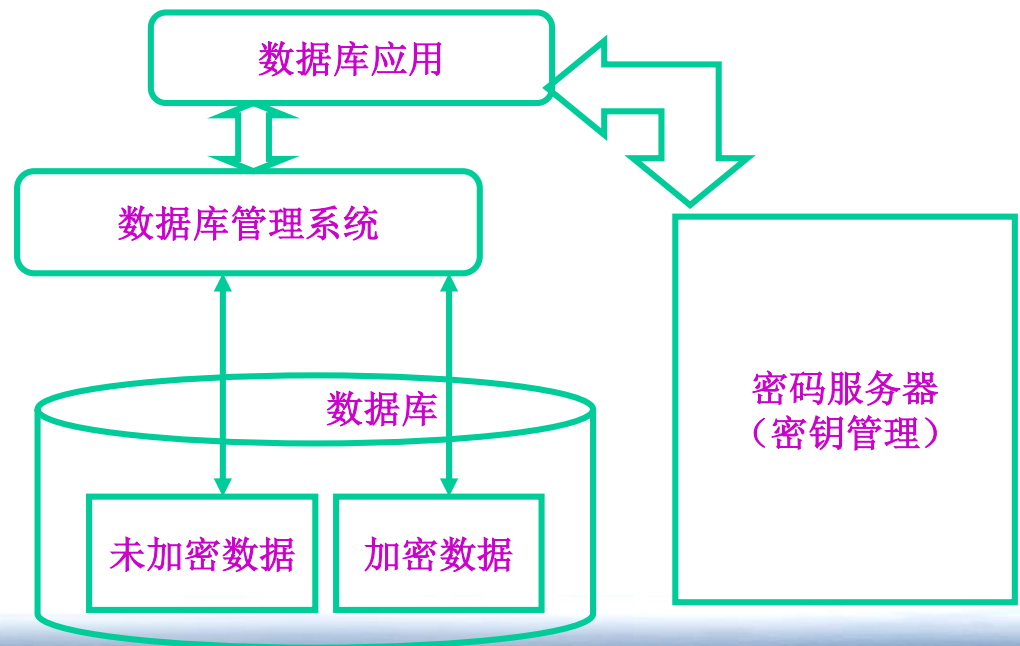
- 在库外加密方式中，加/解密过程发生在DBMS之外，DBMS管理的是密文。
- 加/解密过程大多在客户端实现，也有的由专门的加密服务器或硬件完成。
- 将数据库的文件作为加密对象

□ 优点

- 对DBMS的要求少

□ 缺点

- 效率低
- 数据解密需要很大的时间和空间代价



数据库加密技术——库内加密

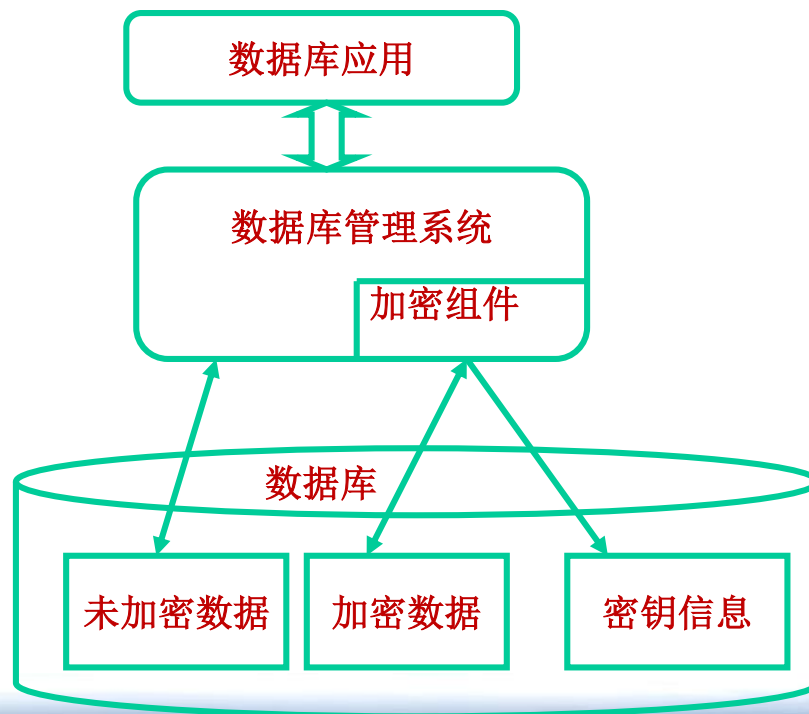
- 库内加密在DBMS内核层实现加密，加/解密过程对用户与应用透明，数据在物理存取之前完成加/解密工作。
- 加密对象为数据库中存储的数据，比如表、记录、元素、数据等。

□ 优点

- 加密的粒度可细化
- 效率较高

□ 缺点

- 针对性较强



库内加密 vs. 库外加密

	库内加密模式	库外加密模式
加解密执行者	DBMS	专门的密码服务器或客户端
对数据库应用是否透明	是	否
服务器端性能影响	服务器运行负担大	基本无影响
密钥管理	库内存储，风险大	专门保护，风险小
是否影响DBMS功能	完全不影响	影响索引等部分功能
密码服务能力	提供的算法等密码服务能力受DBMS限制	可以灵活地变更，提供多种密码服务

数据库加密技术——硬件加密

□ 硬件加密

- 在物理存储器与数据库系统之间的硬件加密装置
- 加密/解密操作由硬件中间设备完成

□ 缺点

- 硬件之间的兼容问题
- 系统变得更复杂

数据库备份技术

数据库备份，是在数据丢失的情况下，能及时恢复重要数据，防止数据丢失的一种重要手段。

一个合理的数据库备份方案，应该能够在数据丢失时，有效地恢复重要数据，同时需要考虑技术实现难度和有效地利用资源。

数据库备份技术

数据库的 备份方法

```
graph TD; A([数据库的备份方法]) --> B(物理备份); A --> C(逻辑备份);
```

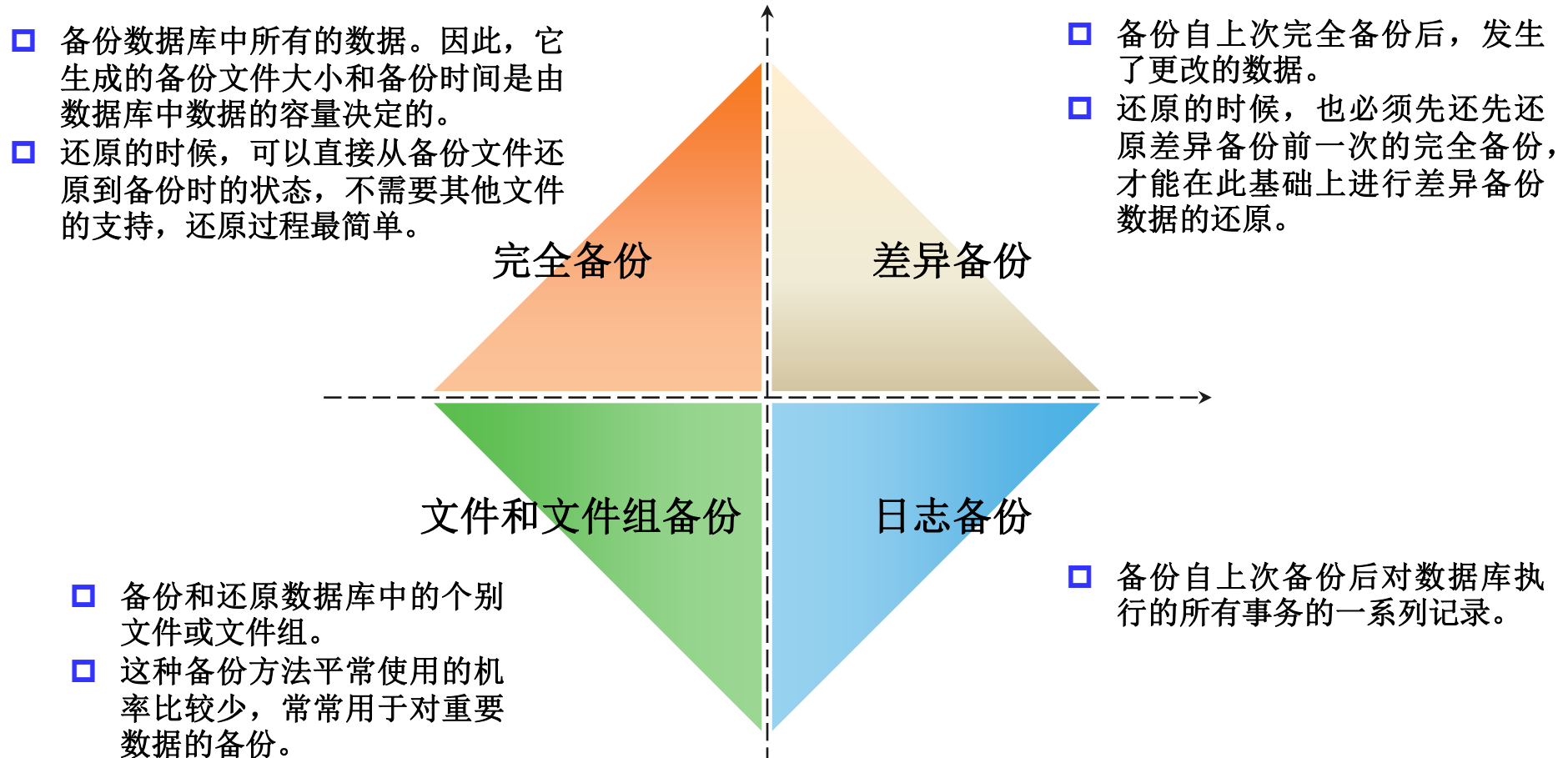
物理备份

该方法实现数据库的完整恢复，但数据库必须运行在归档模式下（业务数据库在非归档模式下运行），且需要极大的外部存储设备，例如磁带库，具体包括冷备份和热备份。

逻辑备份

此方法不需要数据库运行在归档模式下，不但备份简单，而且可以不需要外部存储设备，包括导出/导入。这种方法包括读取一系列的数据库日志，并写入文件中，这些日志的读取与其所处位置无关。

SQL数据库的备份方法



SQL Server提供了四种数据库备份的方法

数据库审计技术

审计是对选定的用户动作的监控和记录，通常用于：

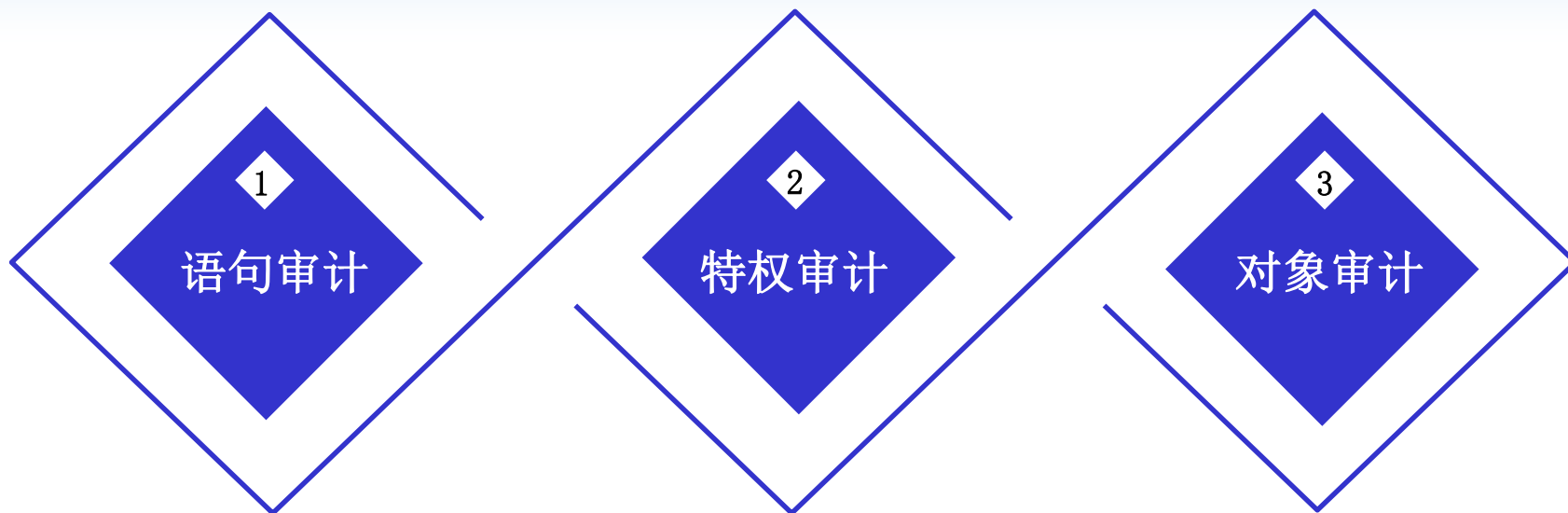
- 审查可疑的活动

例如：数据被非授权用户所删除，此时安全管理员可决定对该数据库的所有连接进行审计，以及对数据库的所有表的成功地或不成功地删除进行审计。

- 监视和收集关于指定数据库活动的数据。

例如：**DBA**可收集哪些被修改、执行了多少次逻辑的I/O等统计数据。

数据库审计技术——审计类型



对某种类型的SQL语句审计，不指定结构或对象。

对执行相应动作的系统特权的使用审计。

对一特殊模式对象上的指定语句的审计。

监视一个或者多个特定用户或者所有用户提交的SQL语句；

监视一个或者多个特定用户或者所有用户使用的系统特权；

监视一个模式里在一个或者多个对象上发生的行为；

数据库审计技术——审计的作用



定位

忠实地记录数据库发生的“一举一动”，能够通过审计这些日志定位系统故障、异常操作和入侵攻击行为。

举证

安全审计日志可以用作法律举证的证据，必要时能帮助进行事故的责任认定。一些行业要求定期对日志进行全面备份并保留相当时间

预警

能够发现潜在的威胁和运行问题，未雨绸缪化解安全和运行风险。在安全事件发生或关键数据遭到严重破坏之前可以预先通过日志异常行为告警方式通知管理人员，及时进行分析并采取相应措施进行阻止，降低安全事件的最终发生率。

数据库审计技术——审计的作用举例

2012年阿里巴巴的去IOE战略取得全面胜利，其技术路线引发了广泛关注和热议。尤其是去Oracle使用开源数据库，在2012.11.11的促销中，淘宝天猫总交易额191亿，支付宝核心数据库集群处理了41亿个事务，执行285亿次SQL，生成15TB日志。



数据库安全技术——A summary



逐层递进的数据库安全构架：
Network -> OS-> DBMS



DBMS层次能够提供一系列安全技术



理解特权、角色、用户三者关系



审计的重要性

Summary of The Class



- 数据库安全问题是怎么产生的？

内因，外因

- 数据库自身的漏洞

设计的，开发的，人为操作的。。。

- 数据库的安全需求

数据独立性、数据安全性、数据完整性、并发控制、故障恢复等

- 数据库的一般性安全机制